

RESOLUTION OF SANCTIONING PROCEDURE

From the procedure instructed by the Spanish Agency for Data Protection and based on the following

BACKGROUND

FIRST: Mr. A.A.A. (hereinafter, the complainant) filed a complaint with the Spanish Agency for Data Protection on July 12, 2022. The complaint is directed against the UNIVERSITY OF MURCIA with NIF Q3018001B (hereinafter, the respondent or UM). The reasons for the complaint are as follows:

The complainant states that he participated in the competition for a position as an assistant professor offered by UM, which was awarded to another candidate. However, considering that the assignment was not appropriate, he appealed the decision in court, and his appeal was upheld, resulting in him being awarded the position. He notes that the other candidate filed an appeal against that ruling, providing, among other documentation, documents submitted by the complainant in a different selection process than the one they participated in, which were provided by UM to that third party, without any legitimacy for doing so.

Among those documents, he indicates that his application and CV submitted for another teaching position and the evaluation report with the detailed grades are included. Both documents are part of the administrative file of that other teaching position to which that third party did not apply as a candidate and, therefore, had no right to access.

Furthermore, these documents were provided without anonymization, allowing access to his ID number, personal phone number, and home address.

He also indicates that the third party was provided with an internal report where his personal data and information regarding a pre-doctoral scholarship from the Séneca Foundation, which he enjoyed for 4 years, are again present.

He submits a copy of the following documentation:

- Appeal filed by the aforementioned third party in which it is indicated that a copy of the following documents from the complainant is provided:
- Application for a certificate from the Séneca Foundation dated October 20, 2021.
- Certificate from the Séneca Foundation received on July 11, 2022.
- Complainant's application for another position.
- Evaluation report of that position.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

SECOND: In accordance with Article 65.4 of Organic Law 3/2018, of December 5, on Personal Data Protection and Guarantee of Digital Rights (hereinafter LOPDGDD), the aforementioned complaint was forwarded to UM for analysis and to inform this Agency within one month of the actions taken to comply with the requirements set forth in data protection regulations.

The forwarding, which was carried out in accordance with the rules established in Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP), was acknowledged on August 4, 2022, as noted in the acknowledgment of receipt in the file.

No response has been received to this forwarding letter.

THIRD: On October 4, 2022, in accordance with Article 65 of the LOPDGDD, the complaint filed by the complainant was admitted for processing.

FOURTH: On October 2, 2023, the Director of the Spanish Agency for Data Protection decided to initiate a sanctioning procedure against the respondent, in accordance with the provisions of Articles 63 and 64 of the LPACAP, for the alleged infringement of Article 5.1.f) of the GDPR and Article 32 of the GDPR, classified under Article 83.5 of the GDPR and Article 83.4 of the GDPR, respectively.

FIFTH: After notifying the aforementioned initiation agreement in accordance with the rules established

in the LPACAP, the respondent submitted a written statement in which, in summary, it stated that:

- In the first allegation, UM points out that Mr. B.B.B. is also a faculty member of this University, with the category of contracted-doctor professor.
 - In the second allegation, UM refers to the fact that Mr. B.B.B. was able to access documents related to selection processes for faculty handled by UM due to his professional category.
 - In the third allegation, UM insists on justifying access to those documents by the personnel who are part of the department.
 - In the fourth allegation, it is emphasized that regardless of the above, the documents are part of the file linked to the selection process that is the subject of judicial litigation between Mr. A.A.A. and Mr. B.B.B. and that, consequently, they were already, obviously, known to Mr. B.B.B.
 - In the fifth allegation, it is mentioned that the data has not been used for any purpose other than being used in the judicial procedure referred to in the complaint.
 - Finally, in the sixth allegation, it is considered that access to and obtaining those documents are legitimized by virtue of the exercise of the right to effective judicial protection.
- However, the allegations were dismissed.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
3/11

SIXTH: On August 14, 2024, a proposal for resolution was made, proposing that the UNIVERSITY OF MURCIA, with NIF Q3018001B, has infringed the provisions of Article 5.1.f) of the GDPR and Article 32 of the GDPR, classified under Article 83.5 of the GDPR and Article 83.4 of the GDPR, respectively.

SEVENTH: The proposal for resolution was notified in accordance with the rules established in the LPACAP, on August 14, 2024, and the respondent did not submit a written statement of allegations within the legally established timeframe.

From the actions taken in this procedure and the documentation in the file, the following has been established:

PROVEN FACTS

FIRST: It is recorded in the file that the APPEAL submitted in the Abbreviated Procedure 203/2021 by Mr. B.B.B. included the following documentation:

- Request for a certificate from the Séneca Foundation dated October 20, 2021.
- Certificate from the Séneca Foundation received on July 11, 2022.
- Request from the claimant for another position.
- Evaluation record of that position.

SECOND: It is recorded in the file that in the application for participation of Mr. A.A.A. in another teaching staff position, the following personal data of the same are included: phone number, postal address, email address, sex, as well as academic qualifications at the undergraduate and postgraduate levels.

LEGAL GROUNDS

I

Competence

In accordance with the powers granted to each supervisory authority by Article 58.2 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), and as established in Articles 47, 48.1, 64.2, and 68.1 of Organic Law 3/2018, of December 5, on the Protection of Personal Data and Guarantee of Digital Rights (hereinafter, LOPDGDD), the Director of the Spanish Data Protection Agency is competent to initiate and resolve this procedure.

Furthermore, Article 63.2 of the LOPDGDD states: "The procedures processed by the Spanish Data Protection Agency shall be governed by the provisions of Regulation (EU) 2016/679, by this organic law, by the regulatory provisions issued for its development, and, in so far as they do not contradict them, subsidiarily by the general rules on administrative procedures."

C/ Jorge Juan, 6

Article 5.1.f) of the GDPR

Article 5.1.f) "Principles relating to processing" of the GDPR establishes:

"1. Personal data shall be:

(...) f) processed in a manner that ensures appropriate security of the personal data, including protection against unauthorized or unlawful processing and against accidental loss, destruction or damage, by means of appropriate technical or organizational measures ('integrity and confidentiality')." In this case, it is established that the personal data of the claimant were improperly exposed to a third party by providing personal data of the claimant such as: ID number (data that appears in the application submitted for another teaching position), personal phone number, and home address, as well as academic data and information contained in the application for a position at the UM and the evaluation record of that position, in which selection process the aforementioned third party did not participate.

Consequently, it is considered that the events that occurred constitute an infringement, attributable to the respondent, for violation of Article 5.1.f) of the GDPR.

Classification of the infringement of Article 5.1.f) of the GDPR

The aforementioned infringement of Article 5.1.f) of the GDPR constitutes the commission of the infringements classified in Article 83.5 of the GDPR, which under the heading "General conditions for the imposition of administrative fines" provides:

"Violations of the following provisions shall be subject to administrative fines of up to 20,000,000 EUR or, in the case of an undertaking, an amount equivalent to 4% of the total annual global turnover of the preceding financial year, opting for the higher amount: a) the basic principles for processing, including the conditions for consent under Articles 5, 6, 7, and 9; (...)"

In this regard, the LOPDGDD, in its Article 71 "Infringements" establishes that "Acts and conduct referred to in paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679, as well as those that are contrary to this organic law, constitute infringements."

For the purposes of the limitation period, Article 72 "Infringements considered very serious" of the LOPDGDD indicates:

"1. In accordance with what is established in Article 83.5 of Regulation (EU) 2016/679, the infringements that constitute a substantial violation of the articles mentioned therein are considered very serious and shall be subject to a limitation period of three years, particularly those..."

C/ Jorge Juan, 6

the following: a) The processing of personal data violating the principles and guarantees established in Article 5 of Regulation (EU) 2016/679. (...)

Proposal for sanction for the infringement of Article 5.1(f) of the GDPR

Without prejudice to the provisions of Article 83.5 of the GDPR, the aforementioned article provides in its paragraph 7 the following:

"7. Without prejudice to the corrective powers of the supervisory authorities under Article 58, paragraph 2, each Member State may establish rules on whether and to what extent administrative fines may be imposed on authorities and public bodies established in that Member State."

For its part, Article 77 "Applicable regime for certain categories of controllers or processors" of the LOPDGDD provides the following:

“1. The regime established in this article shall apply to the processing for which the following are responsible or act as processors:

i) Public Universities.

2. When the controllers or processors listed in paragraph 1 commit any of the infringements referred to in Articles 72 to 74 of this organic law, the competent data protection authority shall issue a resolution declaring the infringement and establishing, where appropriate, the measures that should be taken to cease the conduct or to correct the effects of the infringement that has been committed, except for that provided for in Article 58.2(i) of Regulation (EU) 2016/679 of the European Parliament and of the Council, of April 27, 2016.

The resolution shall be notified to the controller or processor, to the body to which it hierarchically depends, where appropriate, and to the affected parties who had the status of interested parties, where applicable.

3. Without prejudice to the provisions of the previous paragraph, the data protection authority shall also propose the initiation of disciplinary proceedings when there are sufficient indications for it. In this case, the procedure and the sanctions to be applied shall be those established in the legislation on the disciplinary or sanctioning regime that is applicable.

Likewise, when the infringements are attributable to authorities and executives, and the existence of technical reports or recommendations for processing that have not been duly addressed is proven, the resolution imposing the sanction shall include a reprimand naming the responsible position and shall order publication in the Official State Gazette or the corresponding regional gazette.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

6/11

4. The resolutions relating to the measures and actions referred to in the previous paragraphs shall be communicated to the data protection authority.

5. The actions carried out and the resolutions issued under this article shall be communicated to the Ombudsman or, where appropriate, to the analogous institutions of the autonomous communities.”

V

Article 32 of the GDPR

Article 32 “Security of processing” of the GDPR establishes:

“1. Taking into account the state of the art, the costs of implementation, and the nature, scope, context, and purposes of the processing, as well as the risks of varying probability and severity for the rights and freedoms of natural persons, the controller and the processor shall implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk, which may include, among others:

a) the pseudonymization and encryption of personal data;

b) the ability to ensure the ongoing confidentiality, integrity, availability, and resilience of processing systems and services;

c) the ability to restore the availability and access to personal data quickly in the event of a physical or technical incident;

d) a process for regularly testing, assessing, and evaluating the effectiveness of technical and organizational measures to ensure the security of processing.

2. In assessing the adequacy of the level of security, particular consideration shall be given to the risks presented by the processing of data, in particular as a consequence of the accidental or unlawful destruction, loss, or alteration of personal data transmitted, stored, or otherwise processed, or the unauthorized communication or access to such data.

3. Adherence to an approved code of conduct pursuant to Article 40 or to an approved certification mechanism pursuant to Article 42 may serve as an element to demonstrate compliance with the requirements set out in paragraph 1 of this article.

4. The controller and the processor shall take measures to ensure that any person acting under the

authority of the controller or the processor and having access to personal data may only process such data on instructions from the controller, unless required to do so by Union or Member State law.” (the underlining is ours)

It should be noted that the GDPR in the aforementioned provision does not establish a list of security measures that are applicable according to the data being processed, but rather establishes that the controller and the processor shall implement technical and organizational measures that are appropriate to the risk involved in the processing, taking into account the state of the art, the costs of implementation, the

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
7/11

nature, scope, context, and purposes of the processing, the risks of probability and severity for the rights and freedoms of the data subjects. Likewise, the security measures must be adequate and proportionate to the identified risk, indicating that the determination of technical and organizational measures should be made taking into account: pseudonymization and encryption, the ability to ensure confidentiality, integrity, availability, and resilience, the ability to restore availability and access to data after an incident, verification process (which is not an audit), evaluation, and assessment of the effectiveness of the measures.

In any case, when assessing the adequacy of the level of security, particular attention should be paid to the risks presented by the processing of data, such as the destruction, loss, or accidental or unlawful alteration of personal data transmitted, stored, or otherwise processed, or the unauthorized communication or access to such data that could cause physical, material, or immaterial harm.

In this same sense, Recital 83 of the GDPR states that “(83) In order to maintain security and prevent processing from infringing the provisions of this Regulation, the controller or the processor must assess the inherent risks of the processing and apply measures to mitigate them, such as encryption. These measures must ensure an adequate level of security, including confidentiality, taking into account the state of the art and the cost of their implementation in relation to the risks and the nature of the personal data that must be protected. When assessing the risk in relation to data security, the risks arising from the processing of personal data must be taken into account, such as the destruction, loss, or accidental or unlawful alteration of personal data transmitted, stored, or otherwise processed, or the unauthorized communication or access to such data, particularly those that could cause physical, material, or immaterial harm.”

In this case, the UM selects its own teaching staff through selection processes subject to certain requirements of publicity and competitive concurrence, but this should not imply indiscriminate access to personal data and other information derived from such processes, as this poses a risk in the processing to be considered.

Therefore, it must exercise special diligence in the technical and organizational measures to ensure adequate security in the processing of personal data, not only to adequately guarantee confidentiality but also the integrity and availability of the same, establishing appropriate procedures and measures for this purpose. Among others, clearly establish in which cases access to files can or cannot be granted, when information must be provided to third parties, and, if applicable, under what conditions (partially, anonymizing certain data, etc.) and adequately train and raise awareness among its staff regarding this.

However, at the time of the occurrence of the personal data breach, it cannot be claimed that the defendant had the appropriate measures in place based on the estimated possible risks, nor that the training and awareness measures directed at the staff who were to carry out the processing of personal data were sufficient.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

everything insufficient, specifically regarding the provision of documents without previously anonymizing certain identifiable personal and contact data, as well as providing documentation to a third party without legitimacy to do so, as has occurred in the case at hand.

The responsibility of the party being claimed is determined by the security breach evidenced in the claim and the documentation provided, as it is responsible for making decisions aimed at effectively implementing the appropriate technical and organizational measures to ensure a level of security adequate to the risk.

Consequently, it is considered that the known facts constitute an infringement, attributable to the claimed party, for violation of Article 32 of the GDPR.

VI

Classification of the infringement of Article 32 of the GDPR

The infringement of Article 32 of the GDPR could entail the commission of the infringements classified in Article 83.4 of the GDPR, which under the heading "General conditions for the imposition of administrative fines" states:

"Violations of the following provisions shall be subject to administrative fines of up to 10,000,000 EUR or, in the case of an enterprise, an amount equivalent to a maximum of 2% of the total annual global turnover of the previous financial year, opting for the higher amount:

a) the obligations of the controller and the processor under Articles 8, 11, 25 to 39, 42, and 43; (...)"

In this regard, the LOPDGDD, in its Article 71 "Infringements" establishes that:

"Acts and behaviors referred to in paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679, as well as those that are contrary to this organic law, constitute infringements."

For the purposes of the statute of limitations, Article 73 "Infringements considered serious" of the LOPDGDD indicates:

"Based on what is established in Article 83.4 of Regulation (EU) 2016/679, the following are considered serious and shall be subject to a two-year statute of limitations:

f) The failure to adopt those technical and organizational measures that are appropriate to ensure a level of security adequate to the risk of processing, as required by Article 32.1 of Regulation (EU) 2016/679. (...)

VII

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

Proposal for sanction for the infringement of Article 32 of the GDPR

Without prejudice to the provisions of Article 83.5 of the GDPR, the aforementioned article provides in its paragraph 7 the following:

"7. Without prejudice to the corrective powers of the supervisory authorities under Article 58, paragraph 2, each Member State may establish rules on whether and to what extent administrative fines may be imposed on authorities and public bodies established in that Member State."

For its part, Article 77 "Applicable regime for certain categories of controllers or processors" of the LOPDGDD provides the following:

"1. The regime established in this article shall apply to the processing for which they are responsible or processors:

i) Public Universities.

2. When the controllers or processors listed in paragraph 1 commit any of the infringements referred to in Articles 72 to 74 of this organic law, the competent data protection authority shall issue a resolution declaring the infringement and establishing, where appropriate, the measures that should be adopted to cease the conduct or correct the effects of the infringement that has been committed, except for that provided for in Article 58.2.i of Regulation (EU) 2016/679 of the European Parliament and of the

Council, of April 27, 2016.

The resolution shall be notified to the controller or processor, to the body to which it hierarchically depends, where appropriate, and to the affected parties who had the status of interested parties, where appropriate.

3. Without prejudice to the provisions of the previous paragraph, the data protection authority shall also propose the initiation of disciplinary proceedings when there are sufficient indications for it. In this case, the procedure and the sanctions to be applied shall be those established in the legislation on the disciplinary or sanctioning regime that is applicable.

Likewise, when the infringements are attributable to authorities and executives, and the existence of technical reports or recommendations for processing that have not been duly addressed is proven, the resolution imposing the sanction shall include a reprimand naming the responsible position and shall order publication in the Official State Gazette or the corresponding regional gazette.

4. The resolutions related to the measures and actions referred to in the previous paragraphs shall be communicated to the data protection authority.

5. The actions carried out and the resolutions issued under this article shall be communicated to the Ombudsman or, where appropriate, to the analogous institutions of the autonomous communities."

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

10/11

VIII

Adoption of Measures

The text of the resolution establishes what the infringements committed have been and the facts that have led to the violation of data protection regulations, from which it is clearly inferred what measures are to be adopted, without prejudice to the fact that the type of procedures, mechanisms, or specific instruments for implementing them corresponds to the sanctioned party, as it is the data controller who fully knows their organization and must decide, based on proactive responsibility and a risk-based approach, how to comply with the GDPR and the LOPDGDD.

Therefore, in accordance with the applicable legislation and having assessed the criteria for the graduation of the sanctions whose existence has been established,

the Director of the Spanish Agency for Data Protection RESOLVES:

FIRST: TO DECLARE that UNIVERSIDAD DE MURCIA, with NIF Q3018001B, has infringed the provisions of Article 5.1.f) of the GDPR and Article 32 of the GDPR, an infringement classified under Article 83.5 of the GDPR and Article 83.4 of the GDPR, respectively.

SECOND: TO NOTIFY this resolution to UNIVERSIDAD DE MURCIA.

THIRD: TO COMMUNICATE this resolution to the Ombudsman, in accordance with the provisions of Article 77.5 of the LOPDGDD.

In accordance with the provisions of Article 50 of the LOPDGDD, this Resolution will be made public once it has been notified to the interested parties.

Against this resolution, which concludes the administrative procedure in accordance with Article 48.6 of the LOPDGDD, and in accordance with the provisions of Article 123 of the LPACAP, the interested parties may optionally file an appeal for reconsideration before the Director of the Spanish Agency for Data Protection within one month from the day following the notification of this resolution or directly file a contentious-administrative appeal before the Contentious-Administrative Chamber of the National Court, in accordance with the provisions of Article 25 and Section 5 of the fourth additional provision of Law 29/1998, of July 13, regulating the Contentious-Administrative Jurisdiction, within two months from the day following the notification of this act, as provided in Article 46.1 of the aforementioned Law. Finally, it is noted that in accordance with the provisions of Article 90.3 a) of the LPACAP, the firm resolution in the administrative procedure may be provisionally suspended if the interested party expresses their intention to file a contentious-administrative appeal. If this is the case, the interested party must formally communicate this fact by means of a written document addressed to the Spanish Agency for Data Protection, submitting it through the Electronic Registry of the Agency

[<https://sedeagpd.gob.es/sede-electronica-web/>], or through any of the other registries provided for in Article 16.4 of the aforementioned Law 39/2015, of October 1. They must also provide the Agency with documentation that proves the effective filing of the contentious-administrative appeal. If the Agency does not become aware of the filing of the contentious-administrative appeal within two months from the day following the notification of this resolution, it would consider the provisional suspension to be concluded.

938-16012024

Mar España Martí

Director of the Spanish Agency for Data Protection

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es